

CVE-2026-44277

Fortinet FortiAuthenticator Improper Access Control RCE

Threat Intelligence Report | Published: May 13, 2026

Attribute	Detail
CVE ID	CVE-2026-44277
Fortinet Advisory	FG-IR-26-128
Disclosure Date	May 12, 2026
Vulnerability Type	Improper Access Control (CWE-284) → Remote Code Execution
Affected Product	Fortinet FortiAuthenticator (on-premises)
Affected Versions	8.0.0, 8.0.2 6.6.0–6.6.8 6.5.0–6.5.6
Fixed Versions	8.0.3 6.6.9 6.5.7
Not Affected	FortiAuthenticator Cloud (FortiTrust Identity — IDaaS)
CVSSv3 Score	9.1 — Critical
Attack Vector	Network — unauthenticated, remote, no user interaction
Exploit Status	No confirmed in-the-wild exploitation at time of disclosure
Zero-Day	No — patched same day as disclosure
Companion CVE	FortiSandbox critical RCE patched in same advisory cycle
Patch Available	Yes — upgrade to fixed versions via Fortinet support portal

⚠️ AI-ASSISTED REPORT — IMPORTANT DISCLOSURE

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All content, findings, detection rules, and recommendations must be independently reviewed and validated by a qualified security professional before being acted upon or implemented in any environment.

Query Disclaimer: All detection queries (Sigma, KQL, YARA, SPL) are generic templates and will require adaptation to match your organisation's specific environment, data sources, field names, log formats, and SIEM/EDR platform configuration.

Currency: Verify all details against the latest Fortinet PSIRT advisories, NVD, and CISA guidance before relying on this document, as threat intelligence evolves rapidly after disclosure.

1. Executive Summary

CVE-2026-44277 is a critical Improper Access Control vulnerability (CWE-284, CVSS 9.1) in Fortinet FortiAuthenticator, disclosed on May 12, 2026. The flaw stems from insufficient authorisation checks that allow a remote, unauthenticated attacker to execute arbitrary code or commands on affected on-

premises appliances by sending specially crafted HTTP requests — no credentials, no foothold, and no user interaction required.

FortiAuthenticator is a widely deployed Identity and Access Management (IAM) appliance providing multi-factor authentication, single sign-on, and RADIUS/LDAP services for enterprise networks. Its privileged position in the authentication infrastructure makes exploitation particularly severe: a successful attack could allow an adversary to execute commands on the appliance, pivot into authentication infrastructure, forge authentication tokens, or disrupt MFA services across the organisation.

Fortinet has released patched versions (8.0.3, 6.6.9, 6.5.7). FortiAuthenticator Cloud (FortiTrust Identity) is confirmed unaffected. Organisations running on-premises FortiAuthenticator should treat this as a critical, immediate patching priority — especially for any internet-facing instances.

2. Vulnerability Details

2.1 Root Cause

The vulnerability is classified as Improper Access Control (CWE-284). The affected code path performs insufficient authorisation checks before executing privileged operations, allowing a remote caller to bypass authentication entirely. An attacker can send specially crafted requests to trigger the vulnerable path and execute arbitrary commands with the privileges of the FortiAuthenticator service process.

The flaw is categorised under CWE-284 rather than a more specific bypass type (e.g. CWE-287 Authentication Bypass), suggesting the issue is in access control logic applied to a sensitive function rather than in the authentication mechanism itself. This is consistent with a pattern seen in prior Fortinet vulnerabilities where administrative API endpoints lack proper authorisation gates.

2.2 Affected Products & Versions

Branch	Affected Versions	Fixed Version
8.0.x	8.0.0, 8.0.2	8.0.3
6.6.x	6.6.0 through 6.6.8	6.6.9
6.5.x	6.5.0 through 6.5.6	6.5.7
Cloud (FortiTrust Identity)	Not affected	N/A

2.3 Attack Scenarios

Security researchers have identified the following primary exploitation scenarios:

- **Scenario A — Internet-Facing Web UI (Highest Risk):**

FortiAuthenticator instances with the management interface exposed to the internet are directly attackable with no preconditions. An attacker can scan for exposed instances and send crafted requests to achieve unauthenticated RCE in a single HTTP transaction.

- **Scenario B — Internal Network Attacker:**

A threat actor with access to the internal network segment hosting the FortiAuthenticator appliance (e.g. via prior compromise of a workstation or VPN) can exploit the vulnerability to escalate access to the authentication server, enabling credential theft or SSO token forgery.

- **Scenario C — Supply-Chain / Automated Scan:**

Mass-scanning tools can trivially enumerate exposed FortiAuthenticator instances using service fingerprints. Given the critical severity and unauthenticated nature, automated exploitation frameworks are likely to incorporate this CVE rapidly once a PoC circulates.

2.4 CVSS v3.1 Breakdown

Vector String: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H → Score: 9.1 (Critical)

Metric	Value	Rationale
Attack Vector	Network (N)	Exploitable remotely over the network
Attack Complexity	Low (L)	No special conditions or race conditions required
Privileges Required	None (N)	Unauthenticated — no account on the target needed
User Interaction	None (N)	Fully automated exploit, no victim action required
Scope	Unchanged (U)	Exploit stays within the FortiAuthenticator process
Confidentiality	High (H)	Full read access to authentication data and secrets
Integrity	High (H)	Arbitrary command execution enables full write capability
Availability	High (H)	Service disruption / crash of authentication infrastructure

3. Threat Landscape & Context

CVE-2026-44277 was disclosed alongside a companion critical RCE vulnerability in Fortinet FortiSandbox, suggesting a broader audit of Fortinet's access control logic across products. Fortinet network security appliances have historically been high-value targets for nation-state threat actors and ransomware groups: CVE-2022-40684 (FortiOS/FortiProxy auth bypass), CVE-2024-21762 (FortiOS SSL-VPN RCE), and CVE-2026-24858 (FortiOS auth bypass) were all exploited in the wild rapidly following disclosure.

FortiAuthenticator's role as an IAM and MFA gateway makes it a particularly attractive target. Compromising the authentication layer enables attackers to: bypass MFA for the entire organisation, forge RADIUS authentication responses, pivot to Active Directory via LDAP proxy relationships, and issue forged SAML assertions for SSO-integrated applications. These capabilities are highly valued in both espionage and ransomware operations.

At time of writing (May 13, 2026), no confirmed in-the-wild exploitation has been reported. However, given the CVSS 9.1 score, the unauthenticated network-accessible attack vector, and Fortinet's history of rapid PoC development following disclosures, organisations should assume a weaponised exploit is available or imminent and treat patching as an emergency.

4. Mitigation

Controls listed in priority order. Patching is the only complete remediation.

4.1 Upgrade FortiAuthenticator (Primary — Do Immediately)

Apply the appropriate fixed version for your branch:

- Branch 8.0.x → upgrade to FortiAuthenticator 8.0.3
- Branch 6.6.x → upgrade to FortiAuthenticator 6.6.9
- Branch 6.5.x → upgrade to FortiAuthenticator 6.5.7

Download firmware from the Fortinet Support Portal (support.fortinet.com). Follow Fortinet's upgrade path documentation — do not skip major versions. Verify the firmware hash before deployment.

4.2 Restrict Management Interface Access (Immediate Workaround)

If patching cannot occur immediately, restrict access to the FortiAuthenticator web UI:

- Remove the management interface from any internet-facing perimeter — place it behind a jump host or VPN
- Implement firewall ACLs to allow HTTPS access to the management GUI only from authorised management IP ranges
- Disable the web admin UI entirely if management is performed via CLI/SSH only
- Enable FortiAuthenticator's built-in trusted host list for administrator access under System → Admin → Administrators

This does not fix the underlying vulnerability but eliminates the network-accessible attack vector for external attackers.

4.3 Audit Internet-Exposed Instances

Use runZero, Shodan, or your existing asset inventory to identify any FortiAuthenticator instances with the management port (TCP 443/8443) exposed to the internet. Use the Fortinet service fingerprint or HTTP banner to confirm version. Prioritise those for emergency patching.

4.4 Review Admin Accounts and Recent Logins

Post-patch, audit FortiAuthenticator admin accounts for unexpected additions. Review authentication logs for anomalous requests — particularly any unauthenticated or malformed requests to sensitive API endpoints — that may indicate prior exploitation during the window between disclosure and patching.

4.5 FortiAuthenticator Cloud Users

If your organisation uses FortiAuthenticator Cloud (FortiTrust Identity), no action is required for this CVE — Fortinet has confirmed the cloud-hosted service is not impacted. No customer-side remediation steps are needed for this deployment model.

5. Detection

Detection focuses on anomalous HTTP activity against the FortiAuthenticator management interface, unexpected process execution on the appliance, and downstream indicators of authentication infrastructure abuse following a potential compromise.

5.1 FortiAuthenticator Log Analysis — Anomalous Requests

Enable and forward FortiAuthenticator system and admin event logs to your SIEM. Alert on the following patterns:

- HTTP 200 or 302 responses to requests that do not include a valid session cookie or auth header — indicates bypass of authentication check
- Repeated requests to administrative API endpoints (/api/v1/, /admin/, /gui/) from IPs not in the trusted admin host list
- HTTP requests with unusual or malformed headers, oversized payloads, or unexpected HTTP methods (PUT/PATCH/DELETE) to the management interface
- Any command execution events logged by the FortiAuthenticator OS — check /var/log/ on the appliance for shell invocations

5.2 Sigma Rule — Anomalous Unauthenticated Requests to FortiAuthenticator

Generic Sigma rule for SIEM platforms ingesting FortiAuthenticator web server logs:

```
title: Unauthenticated Access Attempt to FortiAuthenticator Admin Interface
id: b8c4e210-3f72-4a19-bcf1-0e2d7a3f5612
status: experimental
description: >
  Detects HTTP requests to FortiAuthenticator management endpoints that
  lack authentication headers – potential exploitation of CVE-2026-44277.
references:
  - https://nvd.nist.gov/vuln/detail/CVE-2026-44277
  - https://www.fortiguard.com/psirt/FG-IR-26-128
tags:
  - attack.initial_access
  - attack.t1190
  - attack.t1078.001
logsource:
  category: webserver
  product: fortiauthenticator
detection:
  selection:
    cs-uri-stem|contains:
      - '/api/v1/'
      - '/admin/'
      - '/gui/'
      - '/login/'
    sc-status:
      - 200
      - 302
```

```

filter_authenticated:
  cs(Cookie)|contains: 'sessionid'
condition: selection and not filter_authenticated
falsepositives:
  - Health check probes that receive redirects to login page (tune sc-status)
  - Initial login page loads before session cookie is set
level: high

```

5.3 KQL — Microsoft Sentinel / Defender for Endpoint

If FortiAuthenticator logs are forwarded to Sentinel via Syslog or CEF connector:

```

// CVE-2026-44277: Anomalous requests to FortiAuthenticator management interface
CommonSecurityLog
| where DeviceProduct contains 'FortiAuthenticator'
| where RequestURL has_any ('/api/v1/', '/admin/', '/gui/')
| where DeviceAction !in ('blocked', 'denied')
| where Message !contains 'sessionid'
| summarize RequestCount=count(), SourceIPs=make_set(SourceIP),
              URIs=make_set(RequestURL) by DeviceName, bin(TimeGenerated, 5m)
| where RequestCount > 3
| order by TimeGenerated desc

```

```

// Downstream: MFA bypass indicator – successful auth with no preceding MFA event
CommonSecurityLog
| where DeviceProduct contains 'FortiAuthenticator'
| where Activity contains 'authentication success'
| join kind=leftanti (
  CommonSecurityLog
  | where DeviceProduct contains 'FortiAuthenticator'
  | where Activity contains 'MFA'
) on SourceUserName, bin(TimeGenerated, 2m)
| project TimeGenerated, DeviceName, SourceUserName, SourceIP, Activity

```

5.4 YARA Rule — Suspicious HTTP Patterns Targeting FortiAuthenticator

For network-based detection on IDS/IPS or PCAP analysis:

```

rule CVE_2026_44277_FortiAuthenticator_Exploit_Attempt {
  meta:
    description = "HTTP request patterns consistent with CVE-2026-44277 exploitation"
    author      = "Threat Intel Team"
    date        = "2026-05-13"
    reference   = "https://nvd.nist.gov/vuln/detail/CVE-2026-44277"
    severity    = "critical"
  strings:
    $http_method = /^(GET|POST|PUT|DELETE|PATCH) \\/api\\v1\\\/ nocase
    $no_auth_1    = "Authorization:" nocase
    $no_cookie    = "Cookie:" nocase
    $fa_host      = "FortiAuthenticator" nocase
    $admin_path   = /\\/(admin|gui|api)\\\/

```

```

condition:
  $http_method and $admin_path and
  not ($no_auth_1 or $no_cookie)
}

```

Note: Tune based on your network topology. Internal health checks may trigger false positives.

5.5 Splunk SPL — FortiAuthenticator Syslog

For environments using Splunk with Fortinet TA:

```

index=fortinet sourcetype=fortinet:fortiauthenticator
| where like(url, "%/api/v1/%") OR like(url, "%/admin/%")
| where isnull(cookie) OR NOT like(cookie, "%sessionid%")
| where status IN (200, 302, 403)
| stats count AS hits, values(url) AS endpoints,
          values(status) AS status_codes by src_ip, host
| where hits > 2
| sort - hits

```

6. Threat Hunting

Run these hunts across at least 30–90 days of historical telemetry to identify potential exploitation that may have occurred prior to detection rule deployment.

6.1 Hunt: FortiAuthenticator Admin Accounts Created Post-Disclosure

Threat actors gaining RCE often create persistent admin backdoors. Hunt for any new administrator accounts created after May 12, 2026:

```

// FortiAuthenticator audit log – admin account creation
index=fortinet sourcetype=fortinet:fortiauthenticator action=add object_type=admin
| where _time > strptime("2026-05-12", "%Y-%m-%d")
| table _time, admin_user, new_account, src_ip
| sort - _time

```

6.2 Hunt: Outbound Connections from FortiAuthenticator Appliance

Post-exploitation C2 beaconing from the appliance itself is a strong indicator of compromise. Hunt for unexpected outbound connections from the FortiAuthenticator IP:

```

index=network sourcetype=firewall
| where src_ip IN (<FortiAuthenticator_IP_list>)
| where dest_port NOT IN (443, 636, 389, 88, 123, 53)
| where NOT dest_ip IN (<known_trusted_IPs>)
| stats count, values(dest_ip), values(dest_port) by src_ip, _time span=1h
| where count > 0

```

6.3 Hunt: RADIUS Authentication Anomalies Post-Exploitation

If FortiAuthenticator was compromised, RADIUS responses may have been forged. Hunt for authentication successes for accounts that have no corresponding MFA challenge or that authenticated from unusual locations/devices:

```
index=fortinet sourcetype=fortinet:fortiauthenticator
| where event_type="radius_authentication" AND result="Accept"
| join user [search index=fortinet sourcetype=fortinet:fortiauthenticator
  event_type="mfa_challenge" result="success"
  | stats count by user, _time span=2m | rename count as mfa_count]
| where isnull(mfa_count)
| table _time, user, src_ip, nas_ip, result
```

6.4 Hunt: Mass Scanning for FortiAuthenticator Instances

Hunt your perimeter firewall/IDS logs for mass HTTP probing consistent with automated scanners targeting FortiAuthenticator service fingerprints:

- HTTP GET requests to /login/index.html or /gui/ from a single IP at >10 requests/minute
- User-Agent strings associated with known scanning tools (Shodan, Censys, Nuclei, nuclei-http)
- Requests containing the FortiAuthenticator version string in the Accept or User-Agent header (as used by some PoC scanners)

6.5 Hunt: Lateral Movement from FortiAuthenticator Segment

If the appliance is compromised, hunt for SMB, WMI, or SSH lateral movement originating from the FortiAuthenticator IP subnet toward domain controllers or other critical infrastructure within the same time window as any detected anomalies.

7. MITRE ATT&CK Mapping

Tactic	Technique / Sub-Technique	Relevance to CVE-2026-44277
Initial Access	T1190 — Exploit Public-Facing Application	Unauthenticated RCE via crafted request to FortiAuthenticator web UI
Execution	T1203 — Exploitation for Client Execution	Code/command execution triggered by the improper access control flaw
Persistence	T1136.001 — Create Local Account	Attacker may create backdoor admin accounts on the appliance
Persistence	T1078.001 — Valid Accounts: Default Accounts	Abuse of admin credentials harvested from compromised appliance
Defense Evasion	T1562.001 — Disable or Modify Security Tools	Disabling logging or MFA enforcement on the appliance post-compromise
Credential Access	T1556.002 — Modify Authentication Process: PAM	Manipulation of RADIUS/LDAP responses to forge authentication results

Credential Access	T1003 — OS Credential Dumping	Harvest stored credentials and RADIUS shared secrets from appliance
Lateral Movement	T1021.002 — SMB/Windows Admin Shares	Move laterally from appliance segment to domain infrastructure
Collection	T1213 — Data from Information Repositories	Enumerate LDAP-connected user stores and SSO configurations
Impact	T1531 — Account Access Removal	Disrupt MFA service to lock out legitimate users (denial of service)

8. Recommended Actions Summary

Priority	Action	Owner	Timeline
P1 — Critical	Upgrade FortiAuthenticator to 8.0.3 / 6.6.9 / 6.5.7	Network/Infrastructure Team	Immediately
P1 — Critical	Restrict management UI access — remove from internet, apply ACLs	Network/Security Team	Within 24 hours
P1 — Critical	Audit all on-premises FortiAuthenticator instances via asset inventory	Vuln. Management	Within 24 hours
P2 — High	Deploy Sigma/KQL/SPL detection rules to SIEM	SOC / Detection Eng.	Within 48 hours
P2 — High	Enable YARA rule on IDS/NDR for network-based detection	Security Engineering	Within 48 hours
P2 — High	Run threat hunt queries across 90-day telemetry	Threat Hunt Team	Within 72 hours
P2 — High	Audit FortiAuthenticator admin accounts for backdoors	IAM / Security Team	Within 72 hours
P3 — Medium	Review RADIUS auth logs for MFA bypass anomalies	SOC / IAM Team	Within 1 week
P3 — Medium	Rotate RADIUS shared secrets and admin credentials post-patch	Network / IAM Team	Within 1 week
P3 — Medium	Confirm patch deployment via compliance dashboard	Vuln. Management	Within 1 week

9. References

- [1] **NVD / NIST.** "CVE-2026-44277 Detail." <https://nvd.nist.gov/vuln/detail/CVE-2026-44277>
- [2] **Fortinet PSIRT.** "FG-IR-26-128 — FortiAuthenticator Improper Access Control." <https://www.fortiguard.com/psirt/FG-IR-26-128>
- [3] **Bleeping Computer.** "Fortinet warns of critical RCE flaws in FortiSandbox and FortiAuthenticator." <https://www.bleepingcomputer.com/news/security/fortinet-warns-of-critical-rce-flaws-in-fortisandbox-and-fortiauthenticator/>
- [4] **Security Affairs.** "Critical Fortinet vulnerabilities fixed in FortiSandbox and FortiAuthenticator." <https://securityaffairs.com/192047/security/critical-fortinet-vulnerabilities-fixed-in-fortisandbox-and-fortiauthenticator.html>
- [5] **runZero.** "Fortinet FortiAuthenticator vulnerability: Find affected assets." <https://www.runzero.com/blog/fortinet-fortiauthenticator/>
- [6] **CIS.** "Multiple Vulnerabilities in Fortinet Products Could Allow for RCE." https://www.cisecurity.org/advisory/multiple-vulnerabilities-in-fortinet-products-could-allow-for-remote-code-execution_2026-049
- [7] **ThreatAFT.** "Fortinet Emergency Alert: Critical RCE Flaws in FortiSandbox & FortiAuthenticator." <https://threataft.com/articles/fortinet-critical-rce-fortisandbox-fortiauthenticator>
- [8] **HKCERT.** "Fortinet Products Multiple Vulnerabilities." https://www.hkcert.org/security-bulletin/fortinet-products-multiple-vulnerabilities_20260513
- [9] **Vulnerability CIRCL.** "CVE-2026-44277 — Vulnerability-Lookup." <https://vulnerability.circl.lu/vuln/cve-2026-44277>
- [10] **CISA.** "Vulnerability Summary for the Week of April 27, 2026." <https://www.cisa.gov/news-events/bulletins/sb26-125>

This report was compiled from publicly available threat intelligence sources. All detection rules are provided for defensive purposes and require environment-specific tuning. Update this document as Fortinet PSIRT releases additional technical details or exploit samples become available.